Resilient Communication Networks

Designing Resilient Communication Networks

Self-Protection Mechanisms – Zero Trust and Intrusion Detection



KOM – Communication Networks Lab
Technical University of Darmstadt
Prof. Dr. Björn Scheuermann (Director)
Dept. of Electrical Engineering and Information Technology
Dept. of Computer Science (adjunct Professor)
www.KOM.tu-darmstadt.de

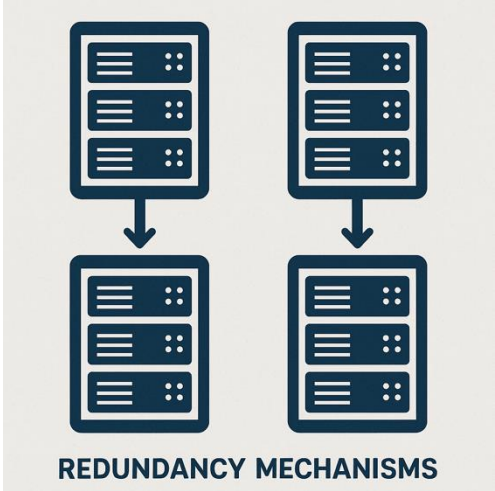
Disclaimer: some of these slides have been derived from Günter Schäfer's lecture „Protection of Communication Infrastructures", Mathias Fischers Lecture „Resilient Networks", Matthias Hollick's Lecture „ Ringvorlesung KRITIS", and Ralf Steinmetz's Lecture "Communication Networks II"

Enablers of Resilience in Communication Networks

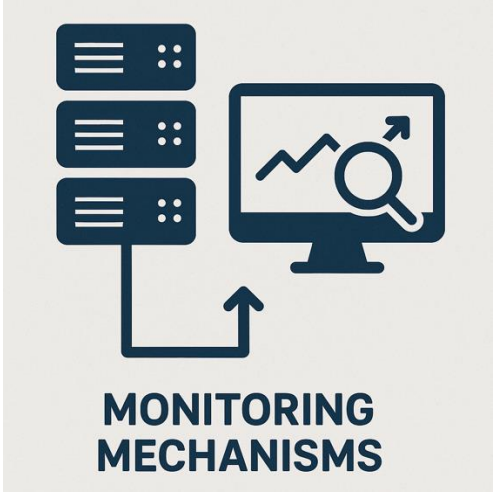
TECHNISCHE UNIVERSITÄT DARMSTADT

Four general classes of enablers

- Redundancy for robustness against disruptions
- Protection for robustness against attacks
- Monitoring for detecting disruptions
- Recovery from failures





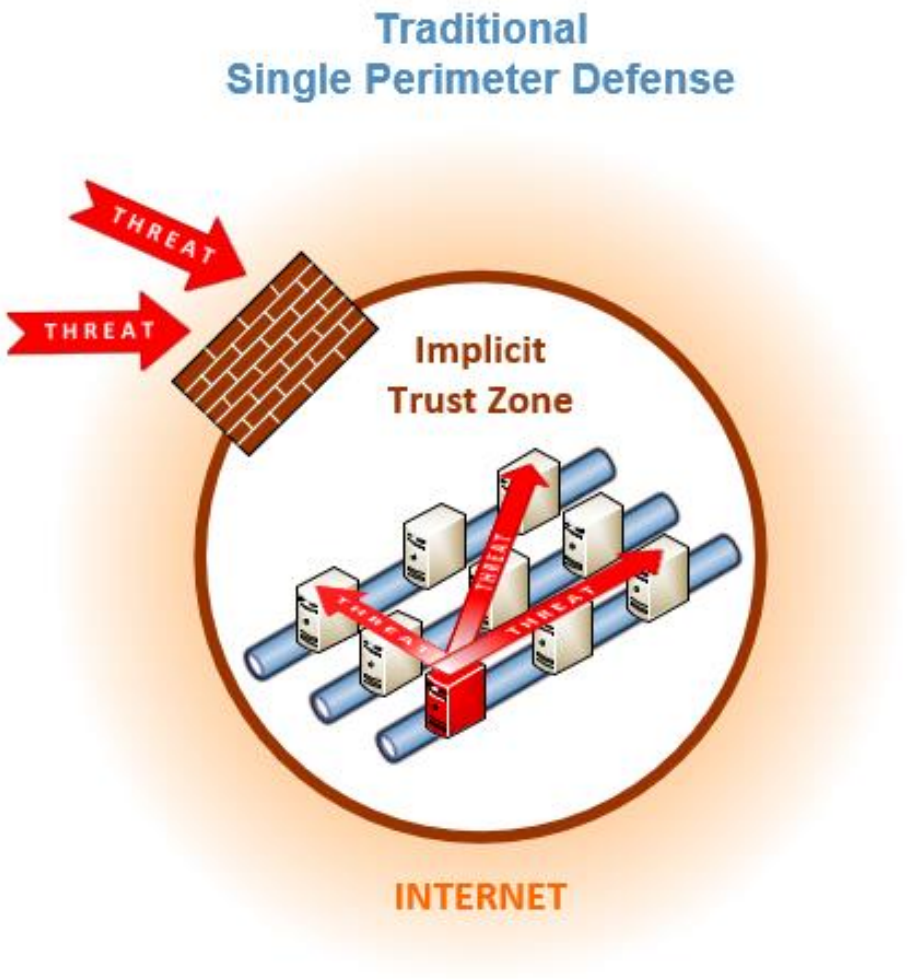




Self-Protection Mechanisms



Traditional networking



Networks are shielded from external traffic using firewalls

- Attackers are only outside of the network
- The network itself is considered secure, i.e., no attackers are assumed to be inside

Can be seen in many protocols

- Earlier versions of SNMP (Simple Network Management Protocol) did not support authentication
- Address Resolution Protocol (ARP), which assumes correct behavior of network devices
- Dynamic Host Configuration Protocol (DHCP) assumes that devices only request a limited number of addresses

https://cyberhoot.com/cybrary/zero-trust/

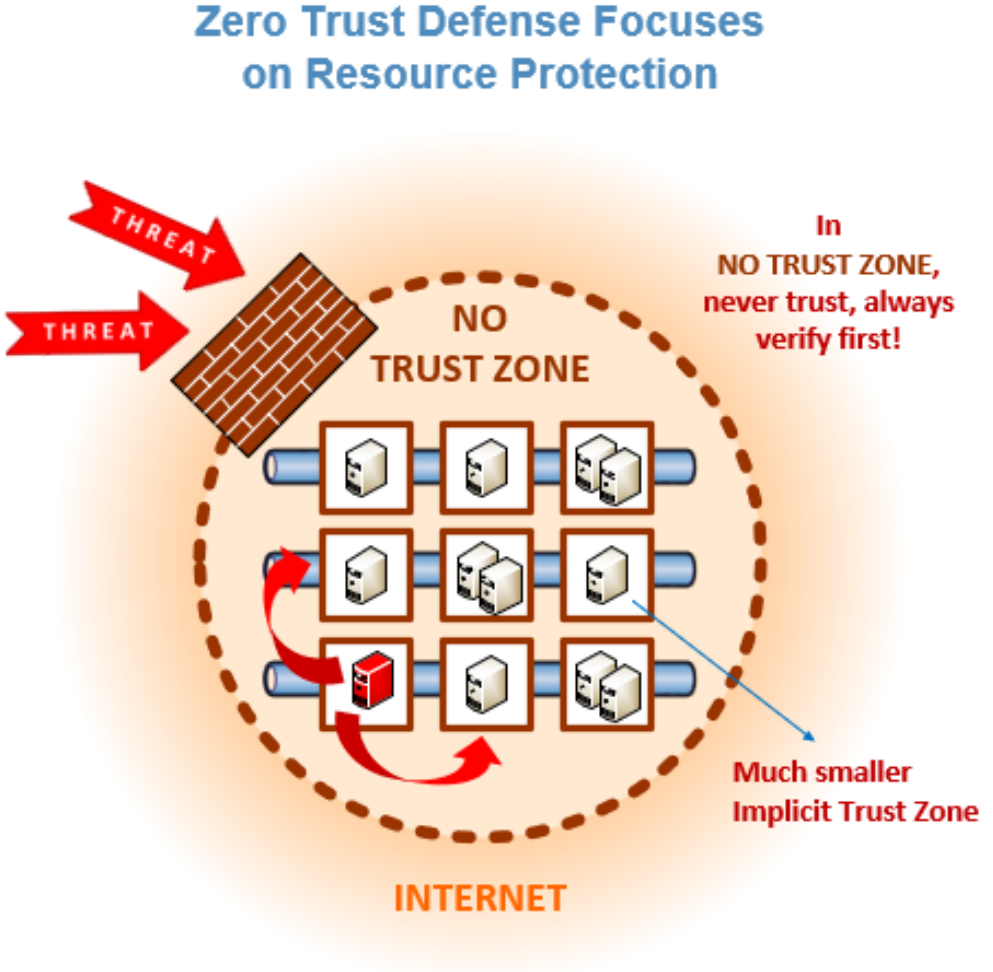
Zero-Trust

In Zero Trust, while the network is still shielded from attacks, there is a much smaller implicit trust zone

- Operations in the network require authentication
- Continuous monitoring of the network to detect anomalies
- Concept of least privileges

Checking of the identify and integrity of users and devices

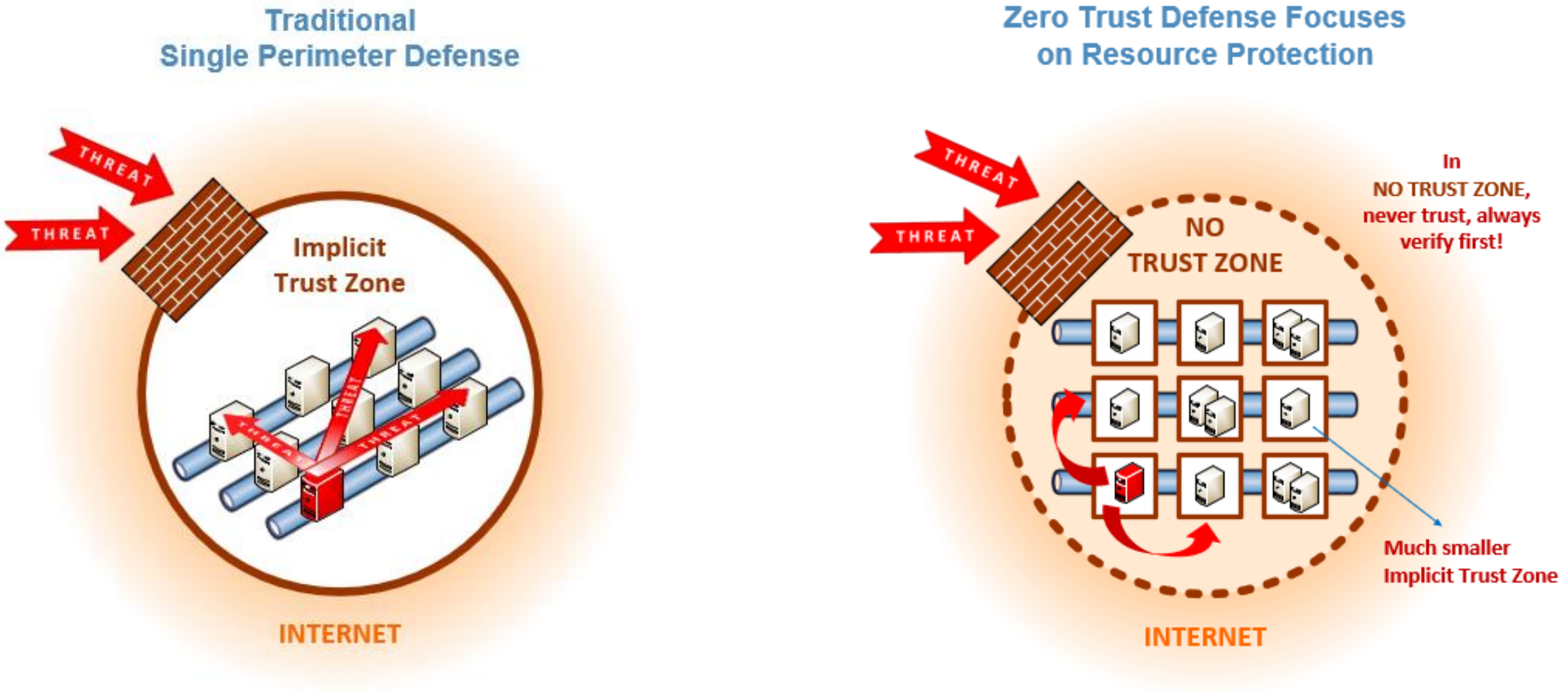




https://cyberhoot.com/cybrary/zero-trust/

Zero-Trust Networks vs. Traditional Networks

TECHNISCHE UNIVERSITÄT DARMSTADT

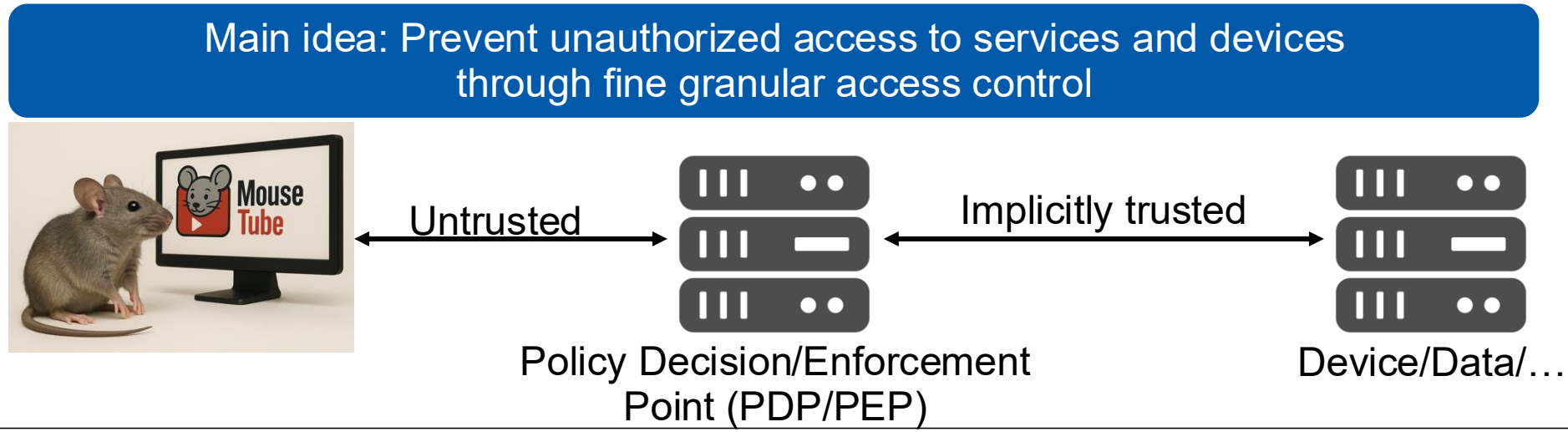


Zero Trust: Definition

“Zero trust is a cybersecurity paradigm focused on resource protection and the premise that trust is never granted implicitly but must be continually evaluated.” (NIST)

Provides concepts and ideas to allow secure network operation assuming that the network is compromised

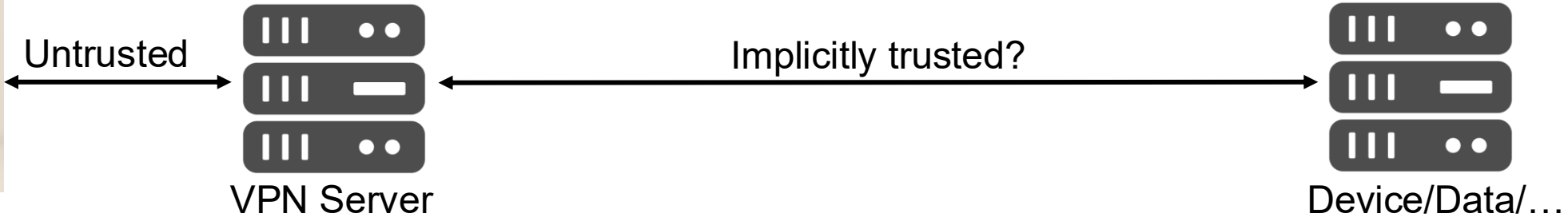
- Constant authentication of users, services, devices, …
- Only the permissions that are necessary for each task should be granted



https://doi.org/10.6028/NIST.SP.800-207

Zero Trust: Definition





A VPN Server can already enforce some policies

The implicit trust zone should be as small as possible

- All traffic after the PEP is considered authenticated and, thus, cannot be blocked anymore
- Can lead to large security holes if managed poorly

Already in traditional networks

- Networks are segmented, i.e., not all users can communicate with all network devices
- However, the smaller these segments, the more accurate the control

Zero Trust: Fundamentals

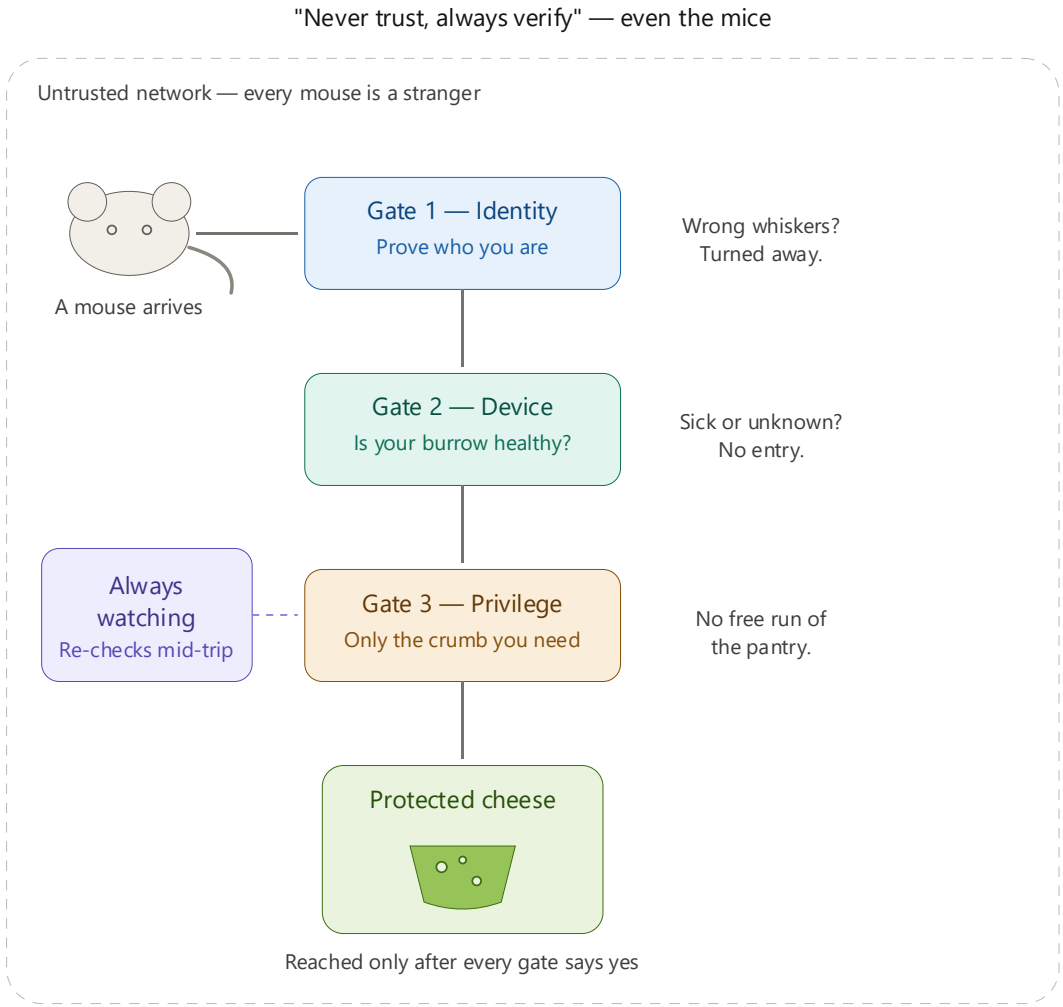
TECHNISCHE UNIVERSITÄT DARMSTADT

All data sources and computing services are considered resources

- All entities in the network should be
  - Servers for processing
  - Switches/Routers for networking
  - IoT devices that collect data

All communication is secured regardless of network location

- The possibility to connect to a network does not imply trust
- Example: Openly available LAN-connection at building
- Transmitted information should always be authenticated and encrypted



Zero Trust: Fundamentals

TECHNISCHE UNIVERSITÄT DARMSTADT

Access to individual enterprise resources is granted on a per-session basis

- Validity of each requester is determined before processing any request to a resource
- Least possible privileges should be used
  - Includes also the visibility of resources

Access to resources is determined by dynamic policy

- Not only based on user or resource, but with more attributes
  - Installed software
  - Previously observed behavior
  - Used device

The network operator monitors and measures the integrity and security of resources

- Continuous diagnostics and mitigation is implemented to monitor devices and applications
- Vulnerable or infiltrated devices can be treated differently

Zero Trust: Fundamentals

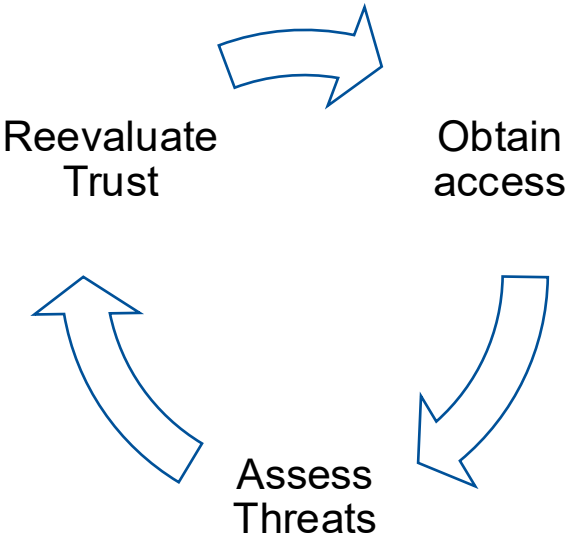
TECHNISCHE UNIVERSITÄT DARMSTADT

Authentication and authorization are strictly enforced before access is allowed

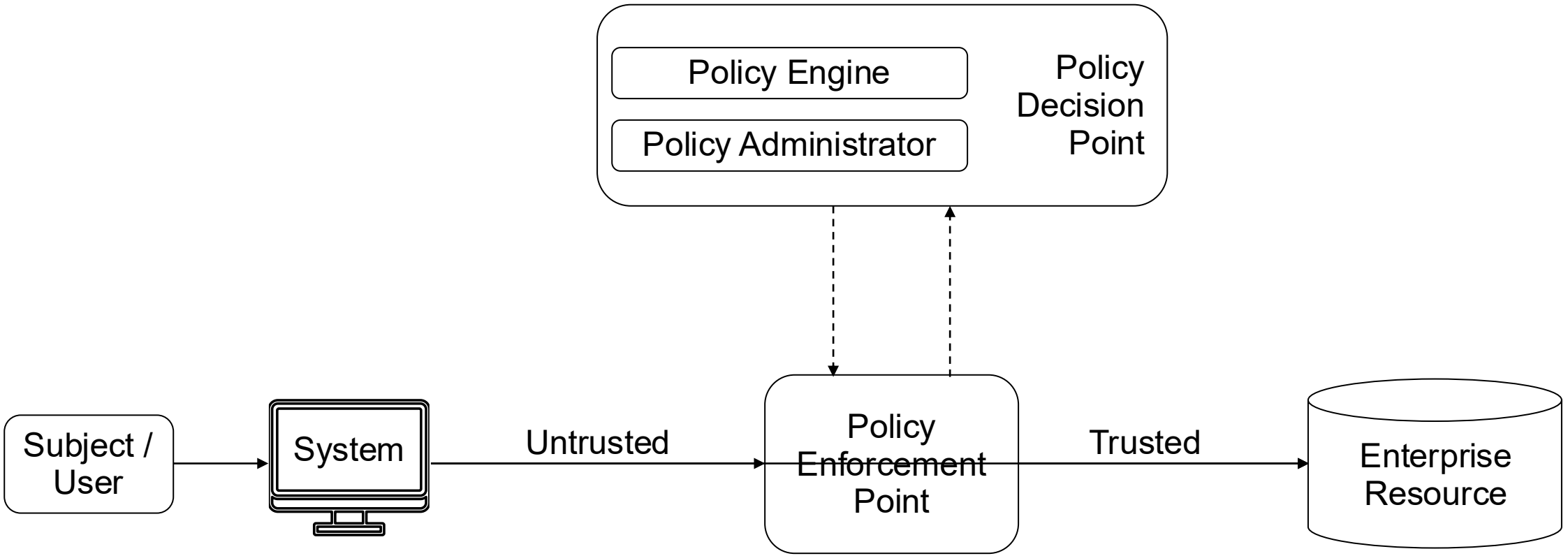
- Credentials and Identity Management are used to authorize user/devices
- Continuous monitoring and re-authentication if suspicion arises
- Important: balance security, availability, usability, and cost efficiency

The network operator collects as much information as possible about the current state of assets, network infrastructure and communications

- Log and analyze network traffic and request behavior
- Improve policies and policy enforcement



Core Components



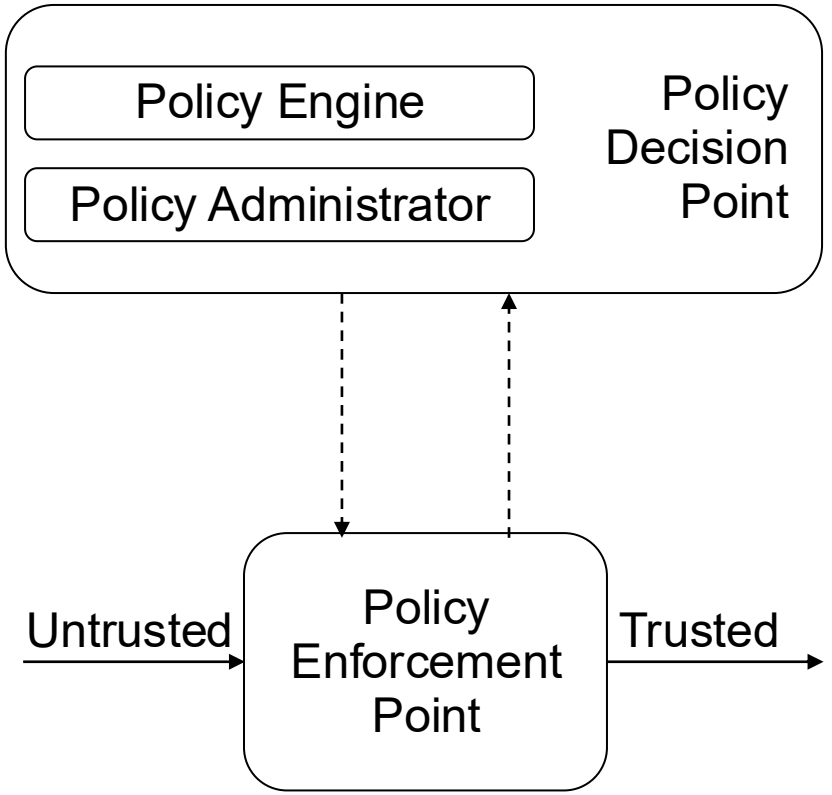
Policy Engine, Policy Administrator and Policy Enforcement Point

Policy Engine

- Responsible for the decision of grating/denying/revoking access to resources
- Based on a policy (e.g., a user can control server XY)
- Based on threat intelligence (e.g., a user has been compromised)

Policy Administrator

- Executes the decision of the policy engine
- Configures policy enforcement points to allow/deny access



Policy Enforcement Point

- Can create/disrupt communication paths between the user and a resource
- Beyond the Policy Enforcement Point(s), the trusted perimeter begins

Implementing a Zero Trust Architecture

TECHNISCHE UNIVERSITÄT DARMSTADT

Policy-based access controls

Micro-segmentation

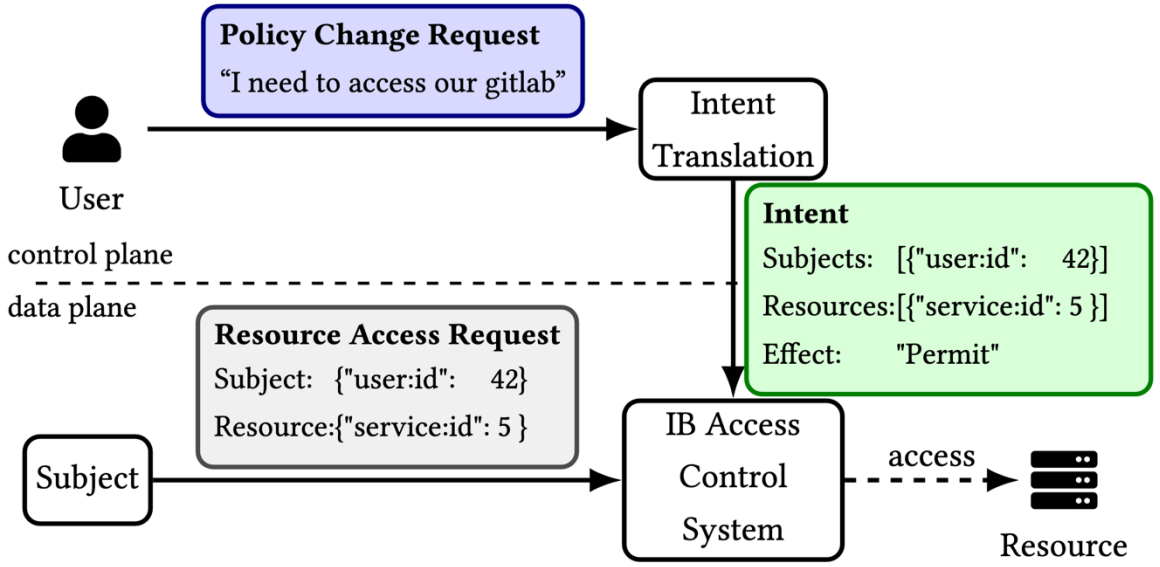
Overlay Network and Software-defined perimeters

Our work: AI-based configuration of network devices

All of this requires a lot of configuration

The configuration of devices causes significant effort and is error-prone

Idea: Use LLMs to configure and manage networks





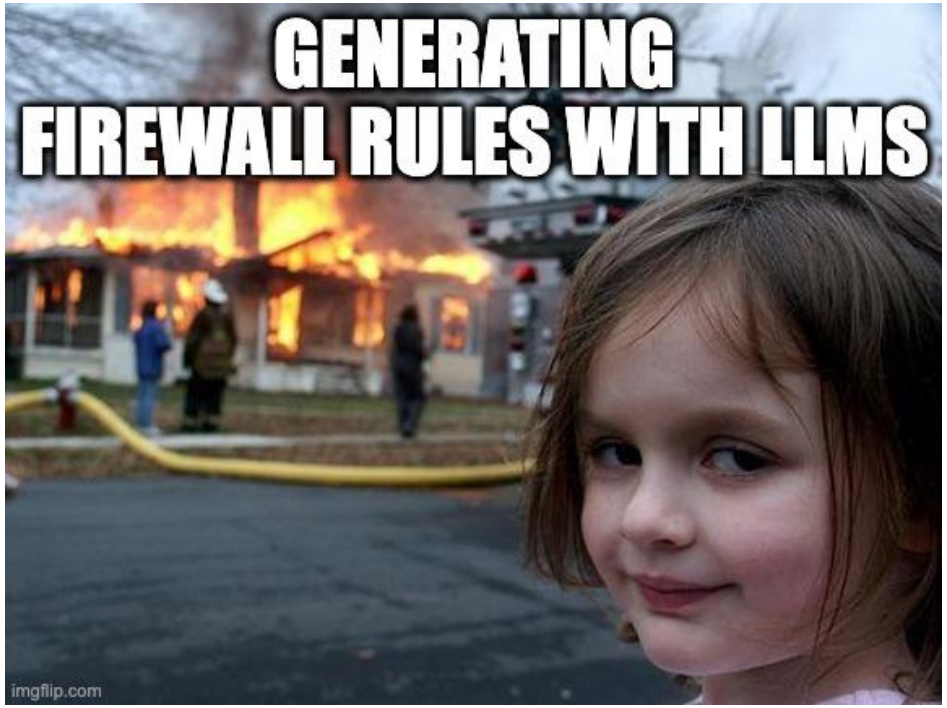
Our work: AI-based configuration of network devices

TECHNISCHE UNIVERSITÄT DARMSTADT

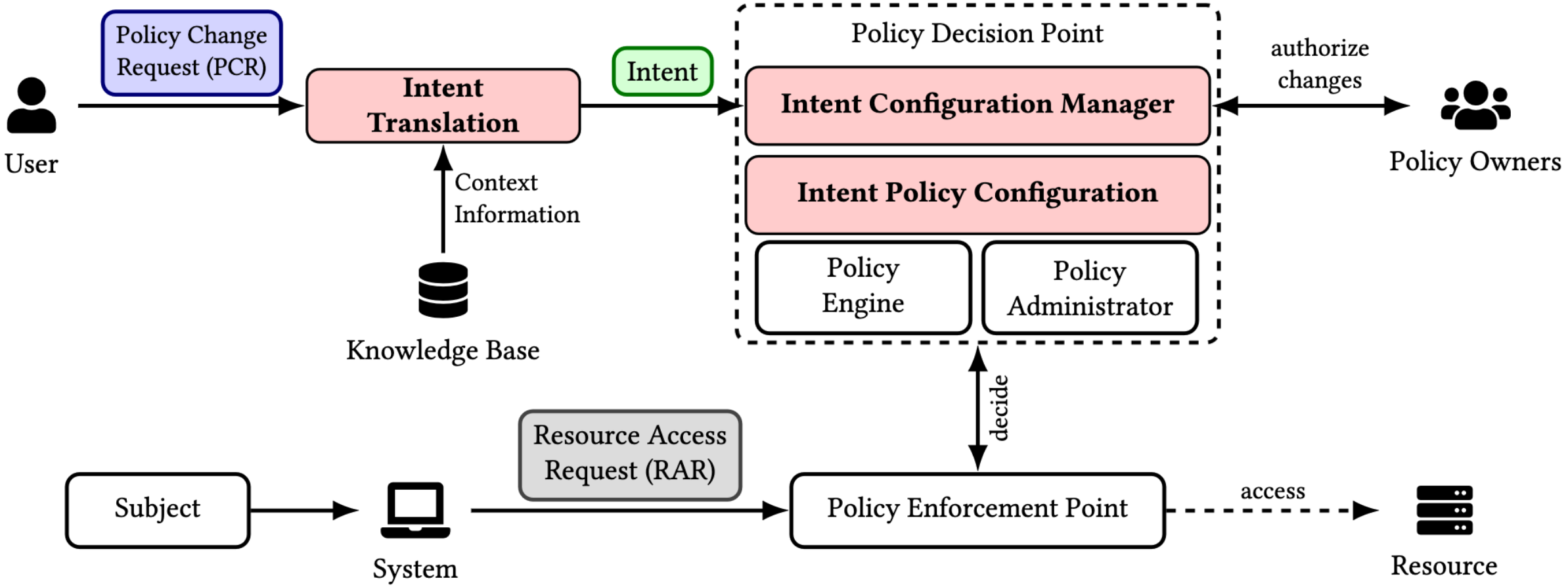
Idea: Users configure their firewall with natural language

Challenges

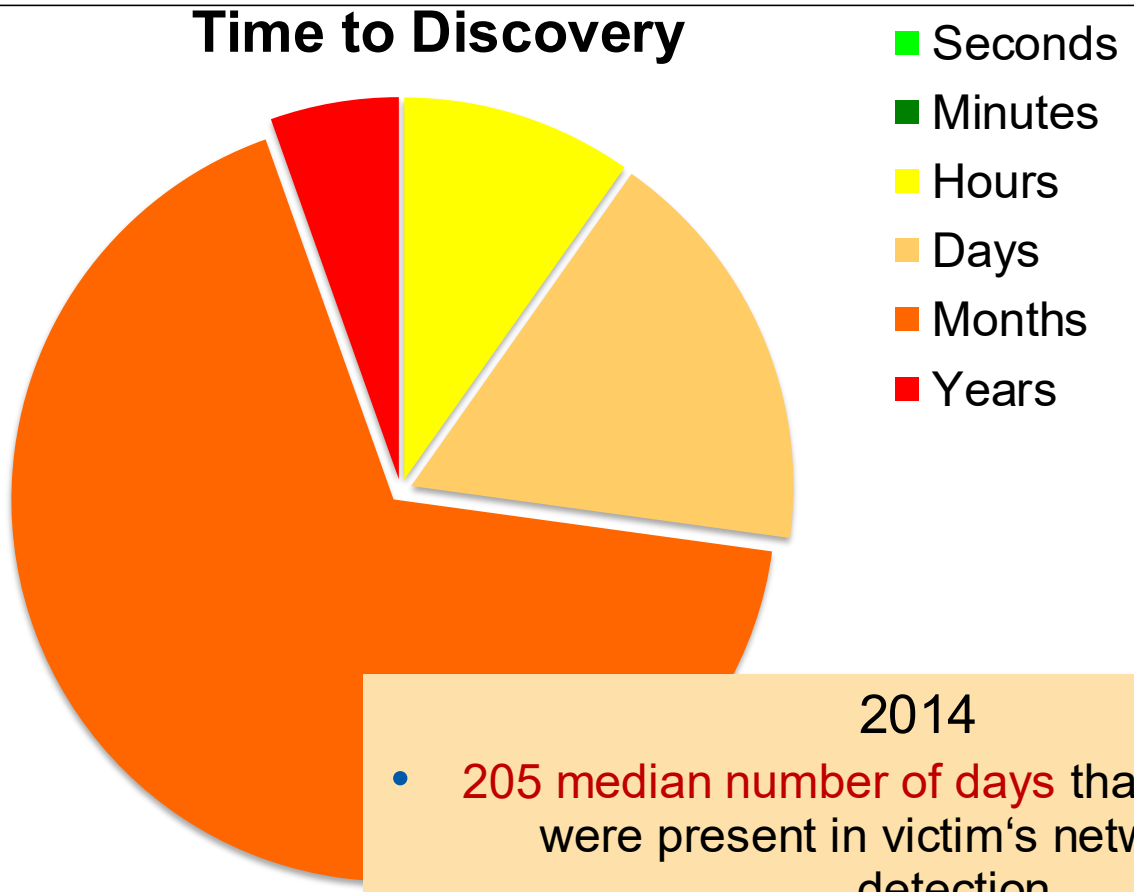
- End-user requests usually lack technical specificity, making them vague and ambiguous
- Interpreting unstructured requests requires mapping varied phrasing to unique institutional identifiers, such as IP addresses
- Conflicting requests from multiple users cannot be resolved independently
- Malicious requests pose security threats



Our work: AI-based configuration of network devices



What happens if the firewall is breached?
Time to Discovery of Attacks



2014

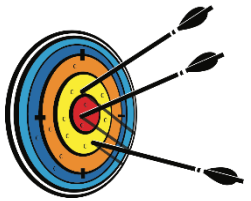
- 205 median number of days that threat groups were present in victim's network before detection
- Longest Presence: 2982 days
- 31% victims discovered breach internally
- 69% victims notified by external entity

Goal of Intrusion Detection/Prevention Systems

TECHNISCHE UNIVERSITÄT DARMSTADT

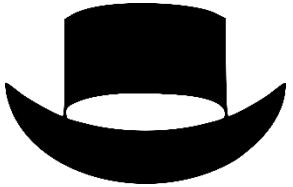
Overall goal:

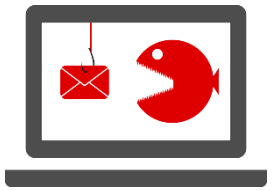
- Intrusion Detection Systems (IDS)
  Supervision of computer systems and communication infrastructures to detect intrusions and misuse
- Intrusion Prevention Systems (IPS)
  Detect and stop intrusion/misuse



What can be attained with intrusion detection?

- Detection of attacks and attackers + detection of system misuse
- Limitation of damage if (automated) response mechanisms exist
- Gain of experience to recover from attack, improve preventive measures
- Deterrence of other potential attackers (if police is able to arrest them!)





Requirements to Intrusion Detection Systems

TECHNISCHE UNIVERSITÄT DARMSTADT

Easy to integrate into a system / network

Easy to configure & maintain

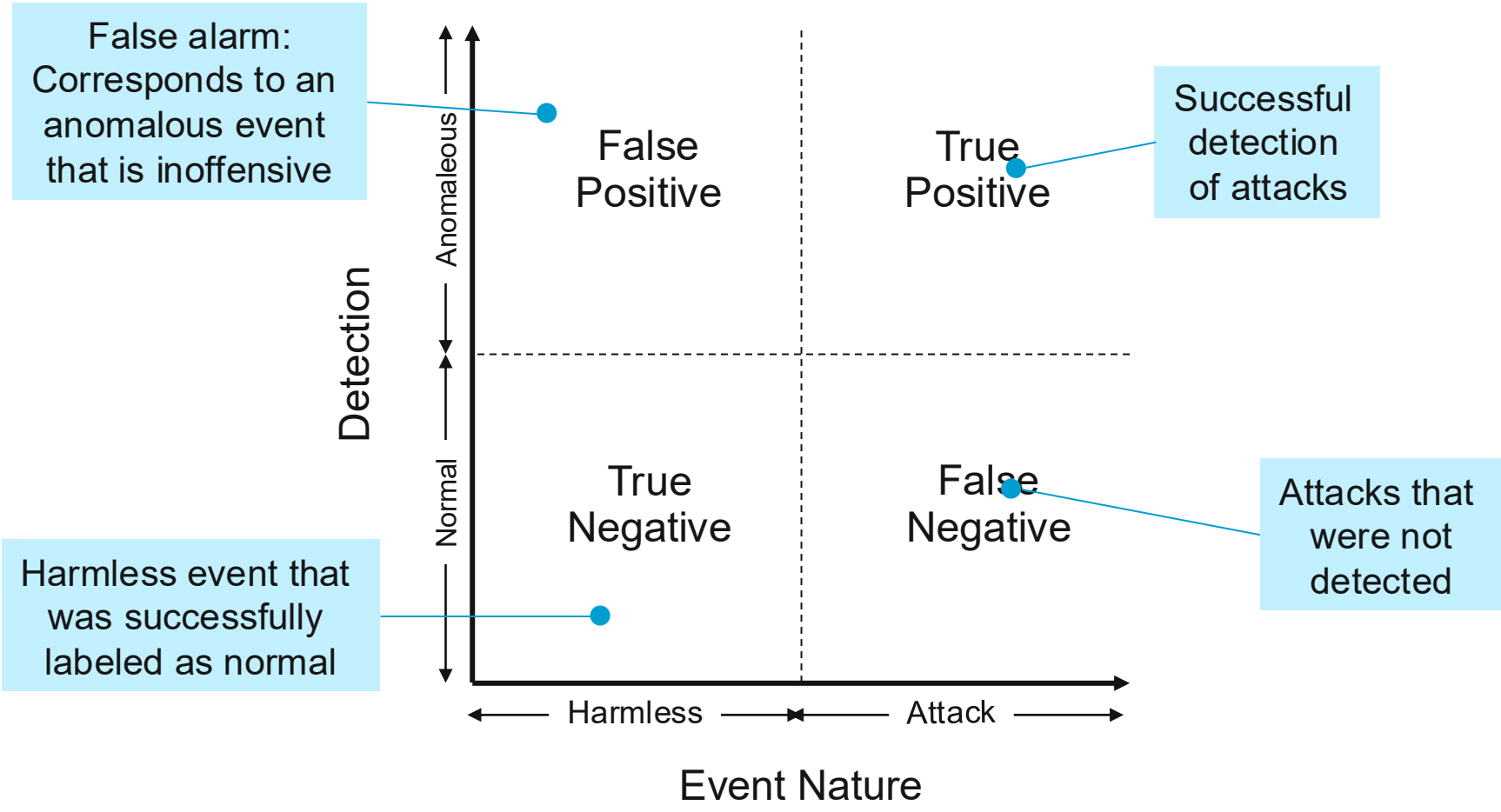
Autonomous and fault tolerant operation

Low resource requirements

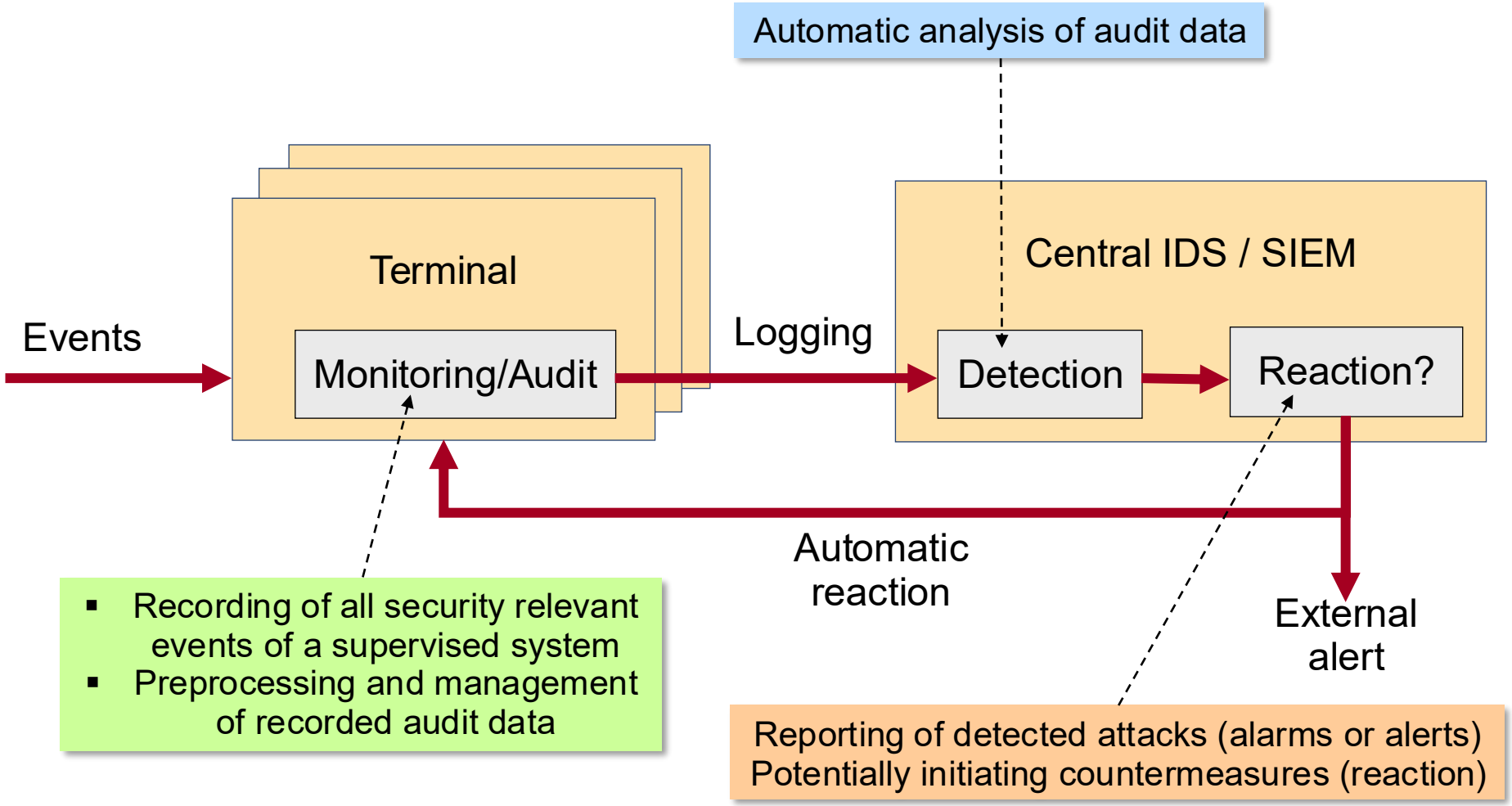
Self-protection, so that IDS cannot be deactivated by deliberate attack (to conceal subsequent attacks)

High accuracy
(= low rate of false positives and false negatives)

Detection Quality



Operation of Intrusion Detection/Prevention Systems



SIEM = Security Information and Event Management

Types of Audit Data

TECHNISCHE UNIVERSITÄT DARMSTADT

Events recorded in a computer system:

- Opening of files
- Execution of programs
- Detected access violation
- Failed password verification
- etc.

Events recorded in a network:

- Connection establishment and release
- Packets transferred from / to specific systems / ports
- Specific signaling events, e.g. ICMP network unreachable message, etc.

Application specific events:

- Have to be programmed for a specific application
- Events are application specific and indicate security relevant activities

Classification of IDS

TECHNISCHE UNIVERSITÄT DARMSTADT

Scope

- Host-based: analysis of system events
- Network-based: analysis of exchanged information (IP packets)
- Hybrid: combined analysis of system events and network traffic

Time of analysis

- Post mortem analysis
- Online analysis

Detection mechanism

- Signature-based
- Policy-based / Misuse-based / Anomaly-based

Types of IDS – Host IDS

TECHNISCHE UNIVERSITÄT DARMSTADT

Host Intrusion Detection Systems (HIDS)

- Works on information available on a system,
  e.g., OS-Logs, application-logs, timestamps
- Can easily detect attacks by insiders, as modification of files, illegal access to files, installation of Trojans or rootkits

Problems:

- has to be installed on every system
- produces lots of information
- often no real-time-analysis but predefined time intervals
- hard to manage a large number of systems

Example of a Host-Monitor – Osquery



TECHNISCHE UNIVERSITÄT DARMSTADT

Allows to use OS as high-performance relational database

- SQL tables representing abstract concepts

Power of complete SQL language on top of dozens of useful tables

processes

All running processes on the host system.

Column	Type	Description
pid	BIGINT_TYPE	Process (or thread) ID
name	TEXT_TYPE	The process path or shorthand argv[0]
path	TEXT_TYPE	Path to executed binary
cmdline	TEXT_TYPE	Complete argv
state	TEXT_TYPE	Process state
cwd	TEXT_TYPE	Process current working directory
root	TEXT_TYPE	Process virtual root directory
uid	BIGINT_TYPE	Unsigned user ID
gid	BIGINT_TYPE	Unsigned group ID
euid	BIGINT_TYPE	Unsigned effective user ID
egid	BIGINT_TYPE	Unsigned effective group ID
suid	BIGINT_TYPE	Unsigned saved user ID
sgid	BIGINT_TYPE	Unsigned saved group ID
on_disk	INTEGER_TYPE	The process path exists yes=1, no=0, unknown=-1
wired_size	BIGINT_TYPE	Bytes of unpagable memory used by process
resident_size	BIGINT_TYPE	Bytes of private memory used by process
total_size	BIGINT_TYPE	Total virtual memory size
user_time	BIGINT_TYPE	CPU time spent in user space
system_time	BIGINT_TYPE	CPU time spent in kernel space
start_time	BIGINT_TYPE	Process start in seconds since boot (non-sleeping)
parent	BIGINT_TYPE	Process parent's PID
pgroup	BIGINT_TYPE	Process group
threads	INTEGER_TYPE	Number of threads used by process
nice	INTEGER_TYPE	Process nice level (-20 to 20, default 0)

```
select * from processes where pid = 1
```

Tables

All Platforms

carbon_black_info
chrome_extensions
cpuid
etc_hosts
etc_protocols
etc_services
interface_addresses
interface_details
kernel_info
listening_ports
os_version
platform_info
process_open_sockets
processes
system_info
uptime

- running processes
- logged in users
- password changes
- USB devices
- firewall exceptions
- listening ports
- ….

usb_devices

USB devices that are actively plugged into the host system.

Column	Type	Description
usb_address	INTEGER_TYPE	USB Device used address
usb_port	INTEGER_TYPE	USB Device used port
vendor	TEXT_TYPE	USB Device vendor string
vendor_id	TEXT_TYPE	Hex encoded USB Device vendor identifier
model	TEXT_TYPE	USB Device model string
model_id	TEXT_TYPE	Hex encoded USB Device model identifier
serial	TEXT_TYPE	USB Device serial connection
removable	INTEGER_TYPE	1 If USB device is removable else 0

https://osquery.io

Example of a Host-Sensor - Osquery

TECHNISCHE UNIVERSITÄT DARMSTADT

High-performance and low-footprint distributed host monitoring

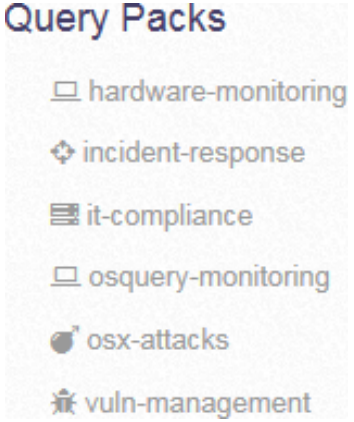
- To query the system in an abstract way
- Independent of OS, software or hardware configuration

Host monitoring daemon

- allows to schedule queries to be executed across entire infrastructure
- takes care of aggregating query results over time and generates logs which indicate state changes in the infrastructure

Cross platform operating system instrumentation framework for

- intrusion detection,
- infrastructure reliability
- or compliance monitoring



https://osquery.io

Only monitoring, no intrusion detection capabilities on its own

Types of IDS – Network IDS

TECHNISCHE UNIVERSITÄT DARMSTADT

Network Intrusion Detection System (NIDS)

- Works on information provided by network, mainly packets sniffed from network layer.

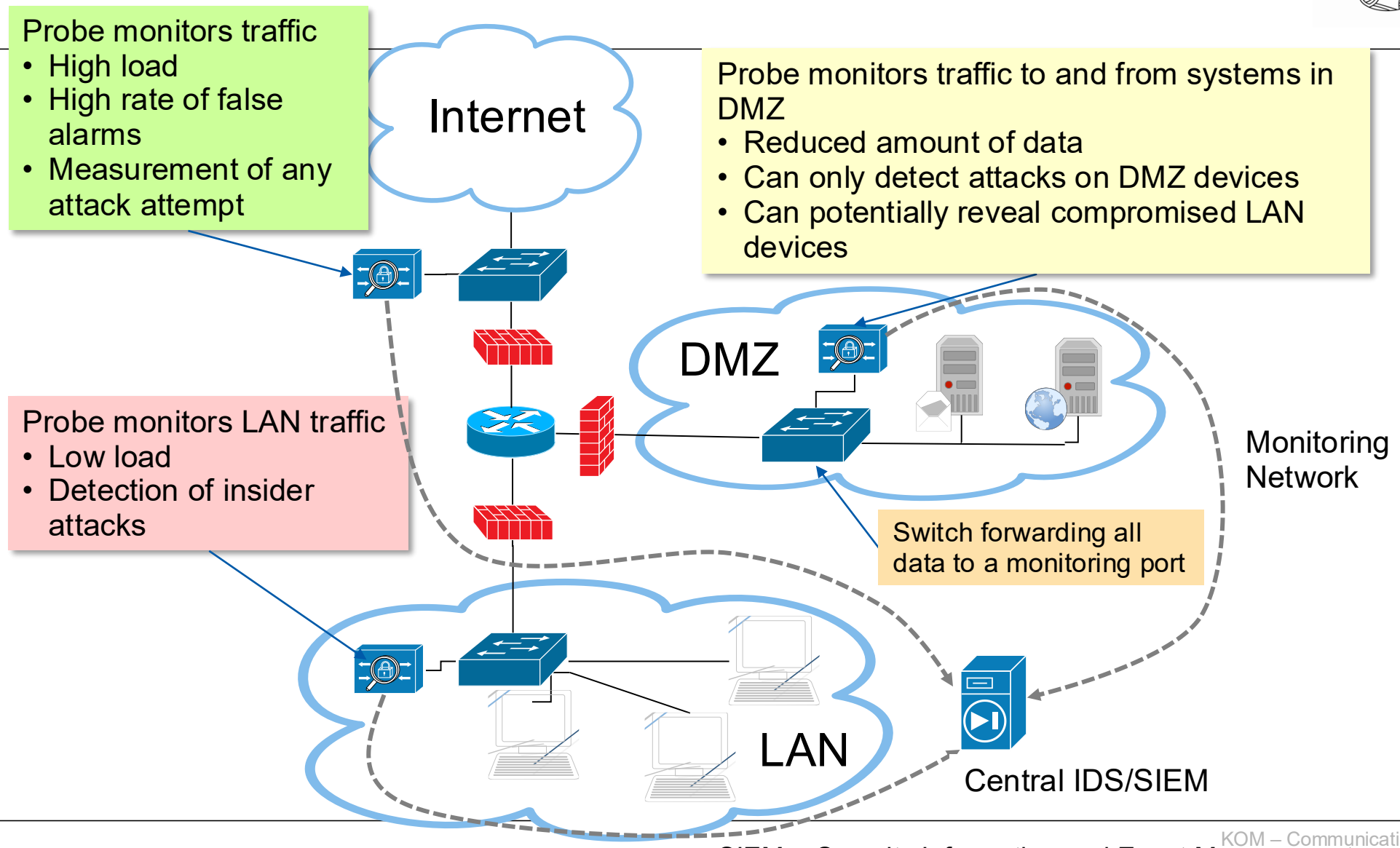
Existing systems use combination of

- signature detection,
- protocol decoding,
- statistical anomaly analysis

Can detect DoS with buffer overflow attacks, invalid packets, attacks on application layer, DDoS, spoofing attacks, port scans

- Often used on network hubs to monitor a segment of the network

Network IDSs



SIEM = Security Information and Event Management

Signature Detection

TECHNISCHE UNIVERSITÄT DARMSTADT

Basic idea

- Some attack patterns can be described with sufficient detail
  → specification of “attack signatures”
- The event audit analyzed if it contains known attack signatures

Identifying attack signatures

- Analyzing vulnerabilities
- Analyzing past attacks that have been recorded in the audit

Drawbacks of signature-based detection

- Requires prior knowledge of potential attacks
- Signature database requires continuous updating
- High rate of false negatives if signature database is not up to date

Signature Detection – Example: Snort





TECHNISCHE UNIVERSITÄT DARMSTADT

Network IDS and intrusion prevention system

- Analysis of IP packets in real time
- Mainly signature based, each intrusion needs a predefined rule

```
alert tcp $HOME_NET any -> any 9996 \
(msg:"Sasser ftp script to transfer up.exe"; \
content:"|5F75702E657865|"; depth:250; flags:A+; classtype: misc-activity; \
sid:1000000; rev:3)
```

Three step processing of captured information (capturing is done by libpcap):

- Preprocessing (normalizing and reassembling packets)
- Detection Engine works on data and decides what action should be taken
- Action (log, alert, pass)

Policy-based Detection

TECHNISCHE UNIVERSITÄT DARMSTADT

Also called misuse-based detection

Basic Idea

- Specify what is allowed in a network and/or what is forbidden
- Violations create alerts
- In that sense, similar to a Firewall

Drawbacks

- You can only detect what you configured / what deviates from what you have configured
- Needs expert knowledge of the system to be protected

Policy-based Detection – Example: Zeek

Real-time network analysis framework

- Primary a network monitoring tool
- Can be used for pure traffic analysis
- Powerful IDS

Focus on

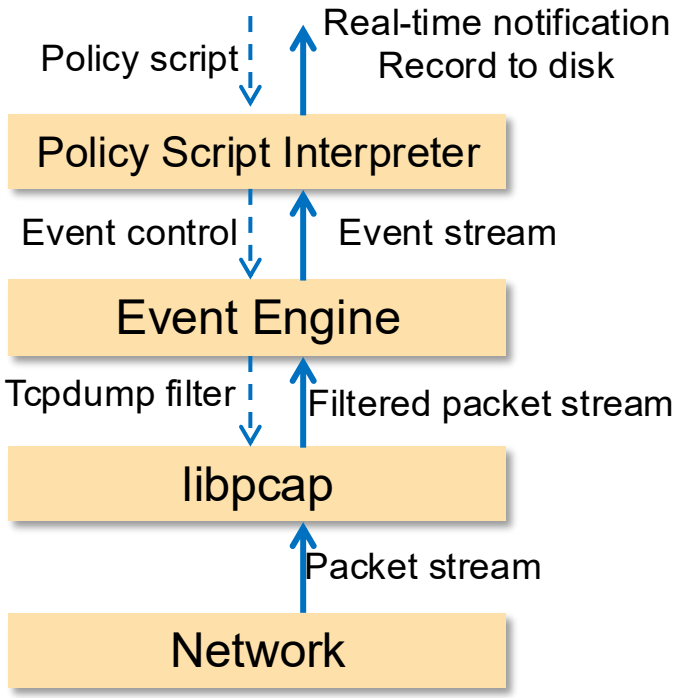
- Application-level semantic analysis
- Policy-based detection in protocols
- Tracking information over time

Zeek comes with >10,000 lines of script code

- Prewritten functionality that's just loaded
- Extensive customization and extension possible
- Growing community writing 3rd party scripts

Intrusion prevention

- Zeek can act as dynamic and intelligent firewall



Anomaly Detection

TECHNISCHE UNIVERSITÄT DARMSTADT

Basic idea – detect behavior that differs significantly from normal use:

Users have certain habits in their system usage:

- Duration of usage
- Login times
- Amount of file system usage
- Executed programs, accessed files, …

Assumption: "normal user behavior" can be described statistically

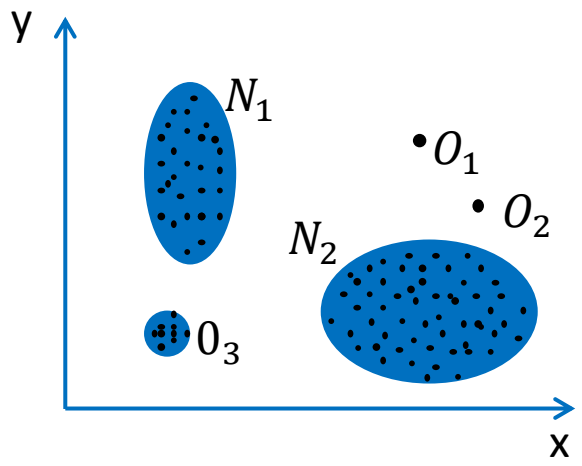
- Requires a learning phase / specification of normal behavior
- Most approaches require labeled data

Analysis:

- compares recorded events with reference profile of normal behavior

Advantage:

- An attack scenario needs not to be defined a priori
- This approach can, in principle, detect unknown attacks

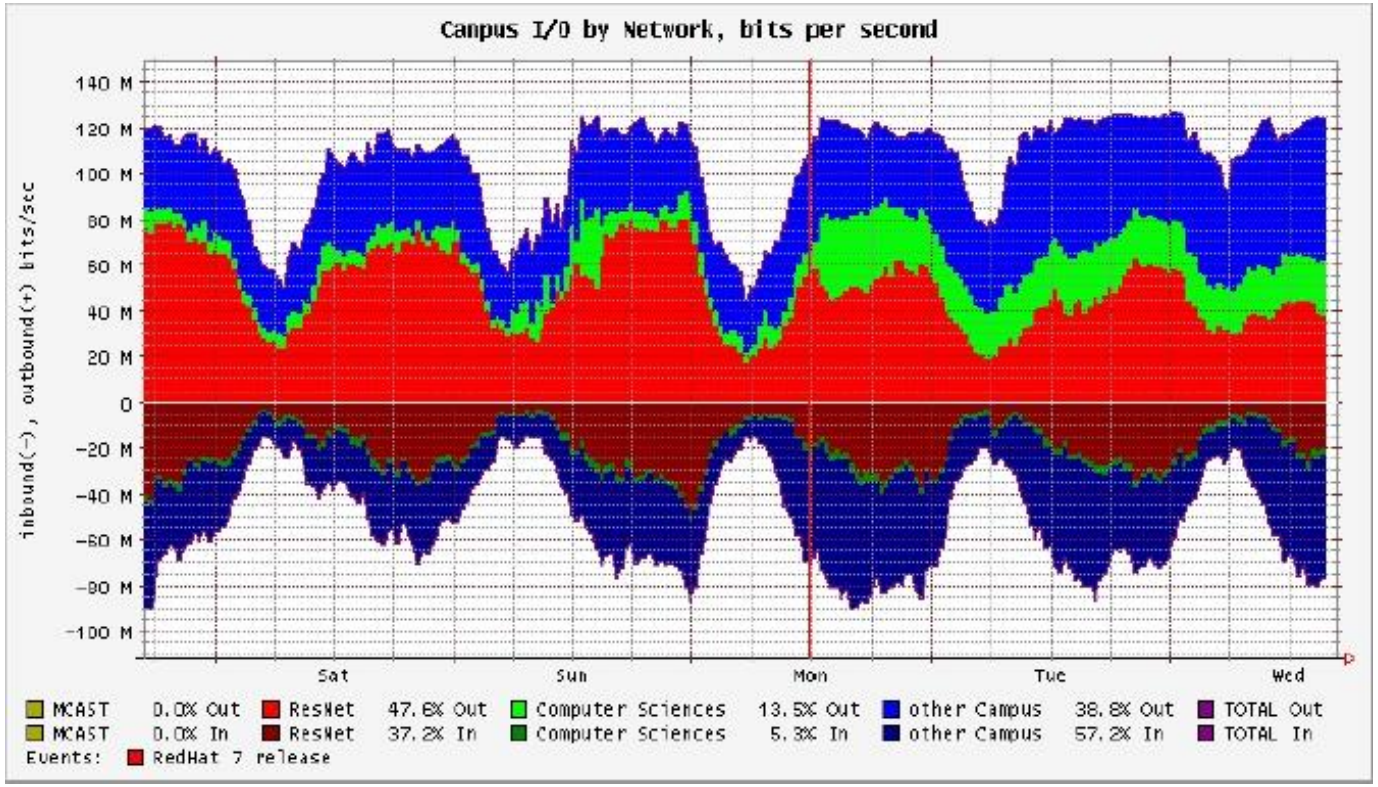


Anomaly Detection

TECHNISCHE UNIVERSITÄT DARMSTADT

“Flash crowd anomalies”

- Caused by software releases or special interest in a web site

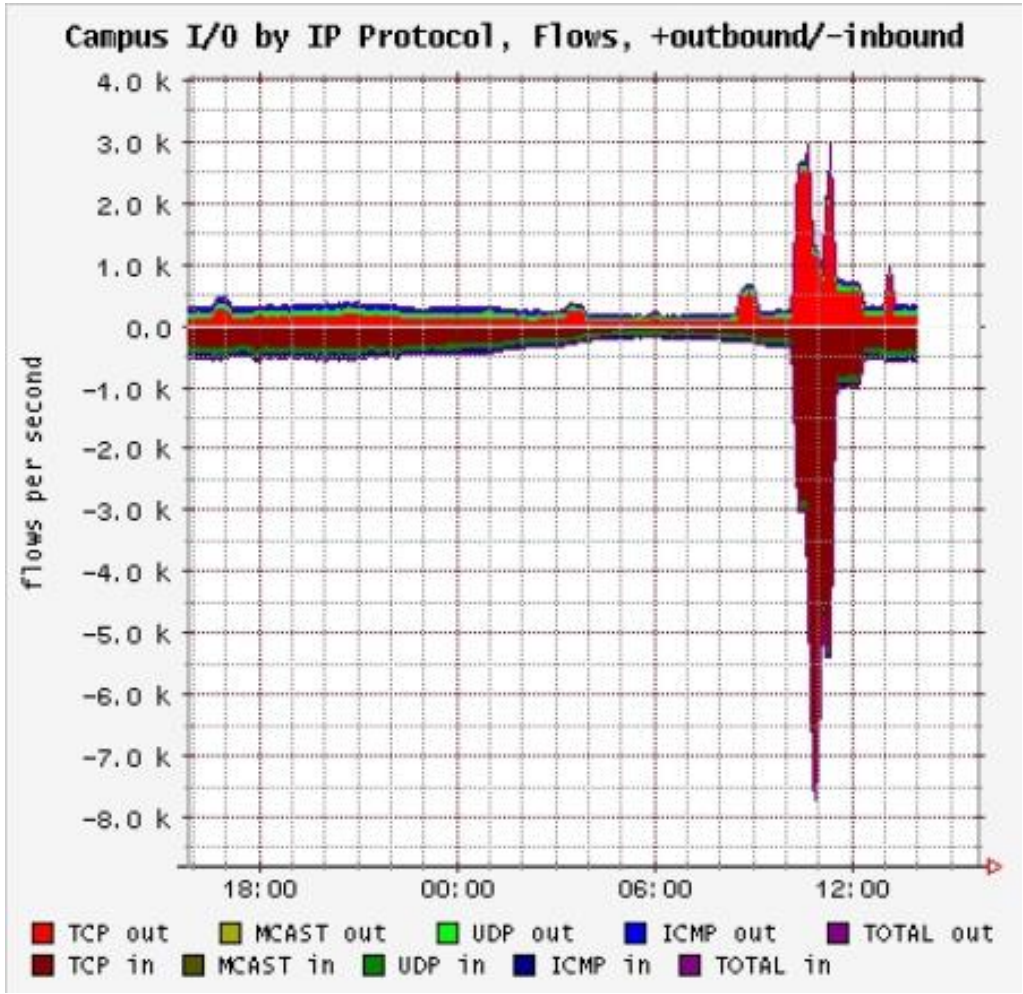


[Bar01]

Anomaly Detection

Network abuse anomalies

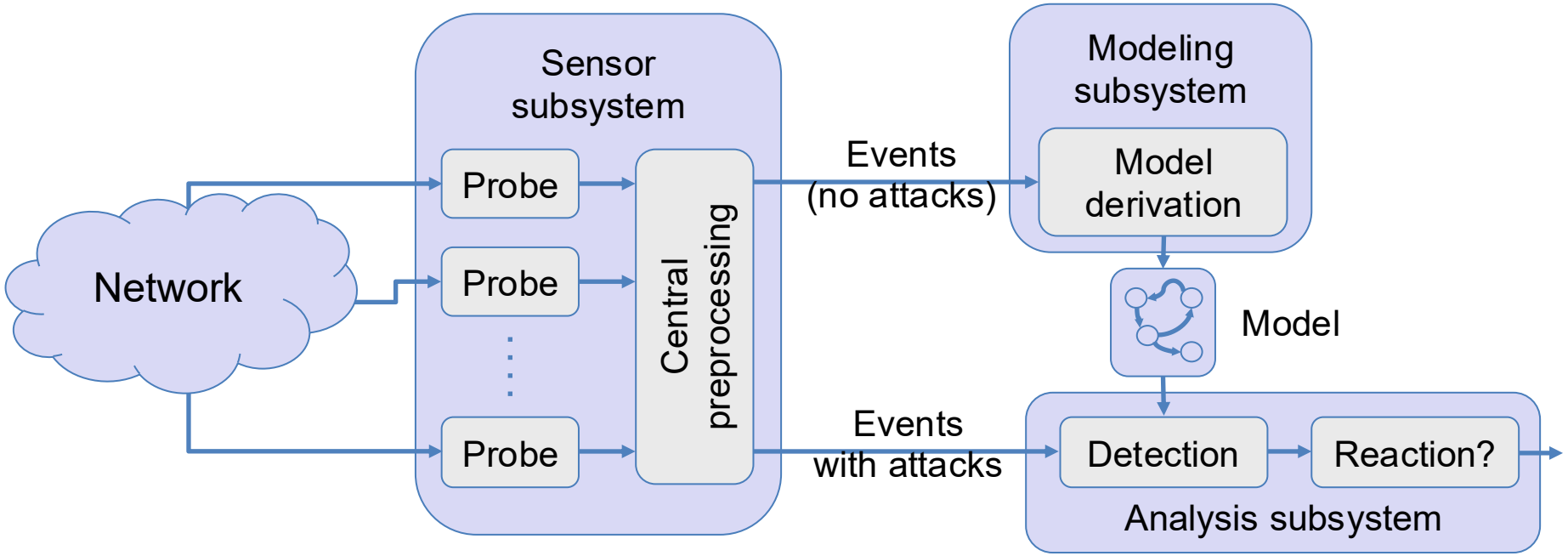
- DoS flood attacks
- Port scans



P. Barford, D. Plonka, Characteristics of Network Traffic Flow Anomalies. Proceedings of ACM SIGCOMM Internet Measurement Workshop, October 2001.

Automatic Anomaly Detection – System model

Generic anomaly detection system



Problems of IDS – Audit Data

TECHNISCHE UNIVERSITÄT DARMSTADT

Amount of log data

- Auditing often generates a rather high data volume
- Significant storage capacities are required
- Processing of audit data should be automated as much as possible

Location of audit data storage

- Alternatives: on specific “log server” or the system to be supervised
- If stored on log server, data must be transferred to this server
- If stored on system to be supervised, the log uses significant amounts of resources of the system

Protection of audit data

- If a system gets compromised, audit data stored on it might get compromised either

Expressiveness of audit data

- Which information is relevant?
- Audits often contain a rather low percentage of useful information

Problems of IDS – Privacy (data protection)

TECHNISCHE UNIVERSITÄT DARMSTADT

User identifying data elements are logged, e.g.,

- Directly identifying elements: user IDs
- Indirectly / partly identifying elements: names of directories and subdirectories (home directory), file names, program names
- Minimally identifying elements: host type + time + action, access rights + time + action

IDS audits may violate the privacy of users

- Violation of the user's right to determine himself which data is collected regarding his person
- Collected information might be abused if not secured properly
- Recording of events puts a psychological burden on users
  ($\rightarrow$ "big brother is watching you")

Potential solution

- Pseudonymous audit: log activities with user pseudonyms and ensure, that they can only be mapped to user IDs upon incident detection

Problems of IDS - Analysis

TECHNISCHE UNIVERSITÄT DARMSTADT

Limited efficiency of analysis

- Most IDS follow a centralist approach for analysis: so-called agents collect audit data and one central evaluation unit analyzes this data
- $\Rightarrow$ No (partial) evaluation in agents
- $\Rightarrow$ Performance bottleneck
- Insufficient efficiency, especially concerning attack variants and attacks with parallel actions

High number of false positives

- In practice, many IDS report too many false alarms (some publications report up to 10.000 per month)
- Potential countermeasure: alert correlation ($\rightarrow$ hierarchical approach)

The bigger Picture of an Attack - Alert Correlation

TECHNISCHE UNIVERSITÄT DARMSTADT

Distributed attacks and multi-step attacks result in large number of alerts

Temporal and spatial distribution of attacks possible

Alert aggregation and correlation required

Operates in three phases

1. Filtering of alerts
2. Clustering/Grouping of alerts, e.g., according to alert attribute similarities
3. Cluster/group interconnection to assemble multi-step attacks

Most correlation algorithms only cover the first two phases

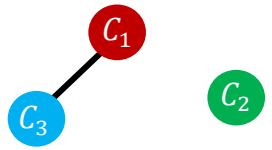
Most can only correlate bulk attacks, e.g., DDoS, port scans, worm spreadings

Alert Level – Alert Correlation Process

TECHNISCHE UNIVERSITÄT DARMSTADT

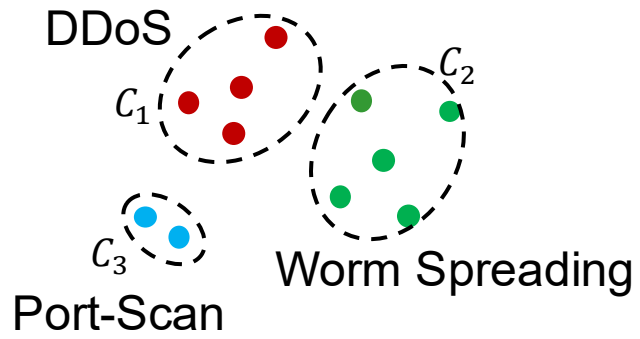
Attack Interconnection

Multi-step Attacks
e.g., Port-Scan -> Targeted attack



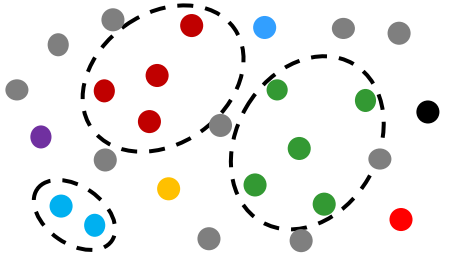
Context Supplementation

Distributed Attacks
DDoS,
Distributed Port-Scans,
Worm spreadings …



Alert Clustering

Alert attributes
Src IP, Dst IP
Src Port, Dst Port
…



Alerts from Network- or Host IDS      ...

Evasion Techniques to Bypass IDS

TECHNISCHE UNIVERSITÄT DARMSTADT

Signature Evasion

- Attack Obfuscation
- Packet Splitting
- Duplicate Insertion
- Packet Overlapping

Anomaly Evasion

- Training Data Injection
- Mimicry Attacks
- Covert Channel Attacks



Our Work: ML-based IDS in Software-defined Networks

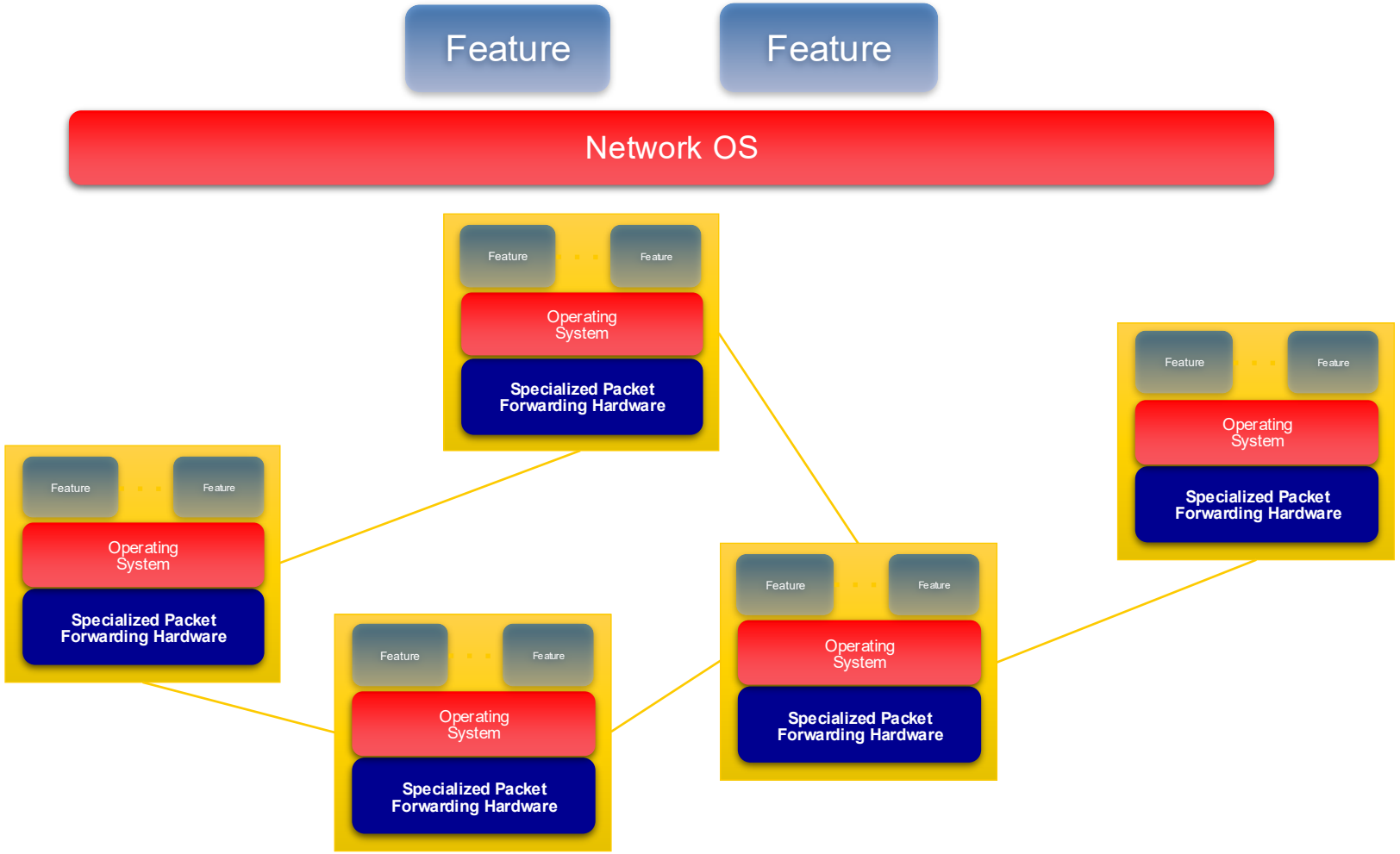
TECHNISCHE UNIVERSITÄT DARMSTADT

What is Software-defined Networking?

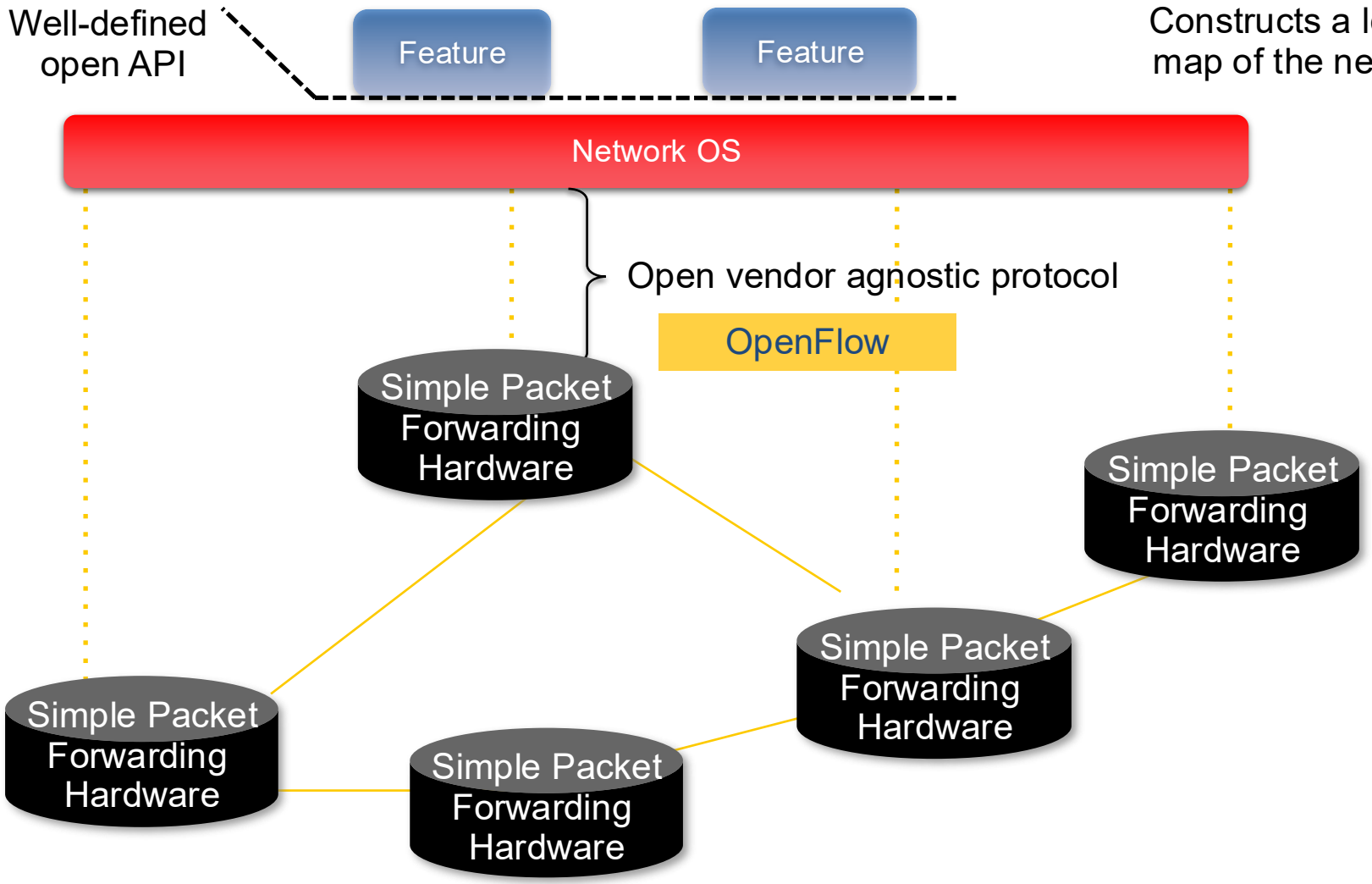
- Instead of decentral control of the network (e.g., through Spanning Tree Protocol at every switch), SDN controls the network via a central entity
- This allows for utilizing all available network information for topology planning, but introduces additional overhead

P. Golchin *et al.*, "CML-IDS: Enhancing Intrusion Detection in SDN Through Collaborative Machine Learning," *2023 19th International Conference on Network and Service Management (CNSM)*, Niagara Falls, ON, Canada, 2023, pp. 1-9, doi: 10.23919/CNSM59352.2023.10327863.

From Vertically Integrated to …



Software-Defined Networks



Our Work: ML-based IDS in Software-defined Networks

TECHNISCHE UNIVERSITÄT DARMSTADT

What is Software-defined Networking?

- Instead of decentral control of the network (e.g., through Spanning Tree Protocol at every switch), SDN controls the network via a central entity
- This allows for utilizing all available network information for topology planning, but introduces additional overhead

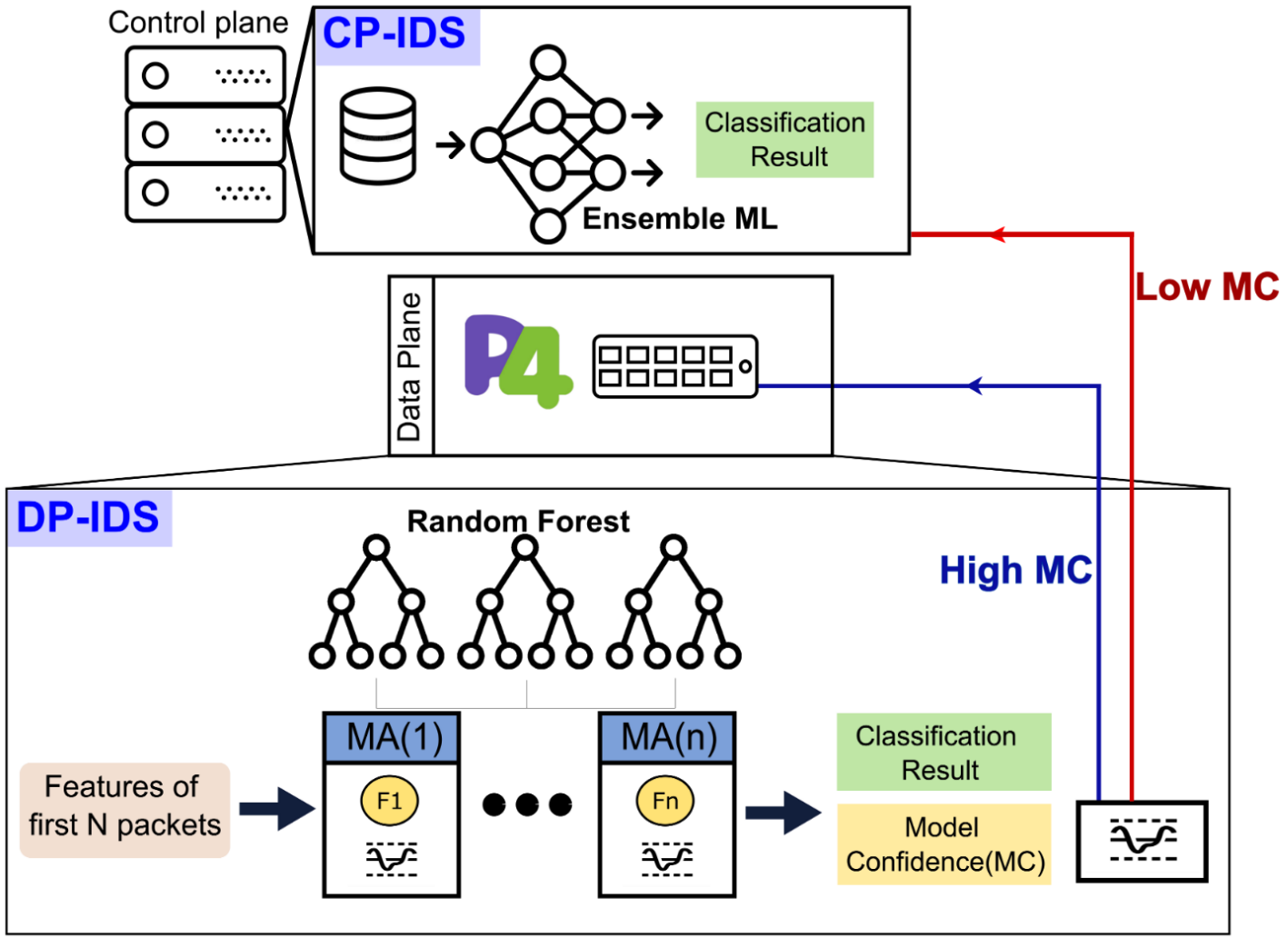
Attacks can be detected both on the control plane and on the data plane

- Control plane detection
  - Very accurate
  - Not very fast and scalable
- Data plane detection
  - Very fast
  - Not very accurate

Combine data plane and control plane detection

P. Golchin *et al.*, "CML-IDS: Enhancing Intrusion Detection in SDN Through Collaborative Machine Learning," *2023 19th International Conference on Network and Service Management (CNSM)*, Niagara Falls, ON, Canada, 2023, pp. 1-9, doi: 10.23919/CNSM59352.2023.10327863.

Our Work: ML-based IDS in Software-defined Networks



Summary

TECHNISCHE UNIVERSITÄT DARMSTADT

IDS

- Signature-based vs. policy-based vs. anomaly-based IDS
- In combination with Firewalls: IPS
- Classification according to kind of sensors deployed, level of distribution

IDS problems

- Huge amounts of data to process
- Limited accuracy and large number of false positives
- Privacy
- IDS evasion techniques

Alert correlation to obtain the bigger picture of attacks

- Alert correlation process